

SMPL.ai — Security one-pager

Audience: Customers and prospects (security questionnaires, early diligence).

Status: Published for sales under NDA (2026-07-29) — not a public marketing page; not SOC 2 certified.

Last updated: 2026-07-29

Owner: Matt Justice

Canonical path: docs/soc2/SECURITY_ONE_PAGER.md

NDA PDF export: docs/soc2/SMPL_Security_One_Pager_2026-07.pdf

Publish record: [evidence/security-one-pager-published-2026-07-29.md](#) · Checklist:

[runbooks/security-one-pager-publish.md](#)

Honest framing: SMPL is pursuing **SOC 2 Type I** (Security + Availability + Confidentiality). We are **not** SOC 2 certified and do **not** claim “SOC 2 compliant” until an independent CPA firm issues a report. Public progress (not certification): [smpl.ai/compliance](#).

Product

SMPL.ai is a B2B SaaS financial intelligence platform (FP&A / ARR / close / board export). We help finance teams read and reconcile finance data. **SMPL does not write back to the customer's GL or ERP.**

Trust & compliance posture

Topic	Current state
SOC 2	Readiness in progress toward Type I (Security + Availability + Confidentiality). Processing Integrity deferred. Privacy not in first engagement.
Certification	None yet — no CPA report issued
Policies	Core information security policies approved internally (including access, change, IR, backup/restore, and AI/LLM data handling). Approving policies ≠ SOC 2 certified
Compliance platform	Deferred DIY for now (internal docs + public progress scoreboard); revisit if enterprise requires a formal GRC tool or at CPA Type I engagement

Architecture & tenant isolation

- **Multi-tenant** application model keyed by organization (`organization_id`).
- Customer users access only their organization's data via authenticated sessions and membership checks.
- Privileged support / white-glove data loads are limited to named operators and are not a substitute for customer admin access.
- Org A ≠ Org B isolation testing completed as readiness evidence (2026-07-29). Detailed test notes are available **under NDA** on request — not a claim of SOC 2 certification.

Authentication

- **Auth.js magic-link** (email) for customer login.
- Organization membership / invites control who can join a tenant.

- Customer SSO is on the product backlog and is **not** required for our current SOC 2 Type I scope narrative.
- Administrative consoles for production hosts use MFA (GitHub, Vercel, Railway, Neon, email/IdP, and related ops vendors).

Encryption & infrastructure (high level)

Control	Practice
In transit	TLS to the application and API (hosted on modern cloud edge/API platforms)
At rest	Customer data in managed Postgres with provider encryption-at-rest defaults
Secrets	Production secrets in host env/secret stores — not in application source
Card payments	Stripe ; SMPL does not store full payment card numbers

Production stack (named for diligence): **Vercel** (web — `www.smpl-ai.com`), **Railway** (API — `sfi-api-production`), **Neon** (Postgres — `smpl-auth-prod`, AWS us-east-1), **GitHub** (source/CI). Exact hosting regions for most other vendors are confirmed during readiness.

AI / LLM usage

- AI narrative / commentary uses **Anthropic** via API calls from the **backend only**.
- API keys are **not** exposed in the browser or static exports.
- Model output is **not** the system of record for financial numbers; governed engine / warehouse outputs are.
- We minimize unnecessary raw personal data in prompts where practical.
- We maintain an internal AI/LLM data-handling policy (prompt minimization, tenant context, no customer data used to train foundation models via our API usage).

Subprocessors (summary)

Vendors that process or store customer-related data in delivering the service typically include:

Vendor	Role
Vercel	Host customer-facing application
Railway	Host API / application services
Neon	Managed Postgres datastore (AWS us-east-1)
Resend	Transactional email (e.g. magic links)
Anthropic	LLM API for commentary features
Stripe	Billing / subscriptions
GitHub	Source control and CI (code; not customer warehouse dumps)

Not on product Customer Data exhibit: Sanity (marketing CMS only); HubSpot (sales CRM only); Squarespace (DNS-only for `smpl-ai.com`). OpenAI and APM/analytics are **not** live in production.

A fuller internal list lives in `docs/soc2/02_subprocessors.md`. Other vendor regions remain TBD where not yet confirmed. Customer DPA / legal exhibit is a separate legal workstream.

Change management (summary)

- Code changes via **GitHub** pull requests (protected main).
- Frontend deploys to **Vercel**; API deploys to **Railway**.
- Production promotion is limited to authorized operators.
- Dependency and secret scanning are enabled on the application repository.

Availability & recovery (summary)

- Primary datastore is managed Postgres with provider backup / point-in-time recovery capabilities.
- We maintain a backup-and-restore policy and have executed a restore fire-drill to a throwaway database branch (production connection strings unchanged).

Incident response

We maintain an approved incident response plan covering detection, containment, recovery, and customer notification when material. We have exercised the plan via tabletop (readiness evidence). Primary security contact: **Matt Justice**.

What we will not claim

- That SMPL is “SOC 2 certified” or “SOC 2 compliant” before a CPA report exists.
- That Processing Integrity (e.g. audited ARR math) is in scope for the first Type I.
- That vendor SOC/ISO report collection is complete until those artifacts exist and are shareable under NDA.

Contact

Security / compliance questions: **Matt Justice** (executive sponsor & security owner).

How sales finds and shares this

Artifact	Location
Canonical markdown	docs/soc2/SECURITY_ONE_PAGER.md
NDA PDF export	docs/soc2/SMPL_Security_One_Pager_2026-07.pdf
Publish evidence	docs/soc2/evidence/security-one-pager-published-2026-07-29.md
Public progress only	smpl-ai.com/compliance — scoreboard, not this one-pager and not certification

Share under NDA (email attachment, data room, or sales KB). Do **not** invent a public /security marketing page unless product decides to. Linking /compliance is OK as readiness progress only.

Document control: aligned with docs/soc2/PROGRESS.md. Update when scope or stack changes. Sharing under NDA ≠ SOC 2 certification.